

Отчет по второму этапу индивидуального проекта

Основы информационной безопасности

Бызова Мария Олеговна, НПИбд-01-23

Содержание

1	Цель работы	5
2	Задание	6
3	Теоретическое введение	7
4	Выполнение лабораторной работы	9
5	Выводы	15
	Список литературы	16

Список иллюстраций

4.1	Клонирование репозитория	9
4.2	Изменение прав доступа	9
4.3	Перемещение по директориям	10
4.4	Создание копии файла	10
4.5	Открытие файла в редакторе	10
4.6	Редактирование файл	10
4.7	Запуск mysql	11
4.8	Авторизация в базе данных	11
4.9	Изменение прав	11
4.10	Перемещение между директориями	12
4.11	Открытие файла в текстовом редакторе	12
4.12	Редактирование файла	12
4.13	Запуск arche	12
4.14	Запуск веб-приложения	13
4.15	“Создание базы данных”	13
4.16	Авторизация	13
4.17	Домашняя страница DVWA	14

Список таблиц

1 Цель работы

Приобретение практических навыков по установке DVWA.

2 Задание

1. Установить DVWA на дистрибутив Kali Linux.

3 Теоретическое введение

DVWA - это уязвимое веб-приложение, разработанное на PHP и MySQL.

Некоторые из уязвимостей веб приложений, который содержит DVWA: - Брутфорс: Брутфорс HTTP формы страницы входа - используется для тестирования инструментов по атаке на пароль методом грубой силы и показывает небезопасность слабых паролей. - Исполнение (внедрение) команд: Выполнение команд уровня операционной системы. - Межсайтовая подделка запроса (CSRF): Позволяет «атакующему» изменить пароль администратора приложений. - Внедрение (инклюд) файлов: Позволяет «атакующему» присоединить удалённые/локальные файлы в веб приложение. - SQL внедрение: Позволяет «атакующему» внедрить SQL выражения в HTTP из поля ввода, DVWA включает слепое и основанное на ошибке SQL внедрение. - Небезопасная выгрузка файлов: Позволяет «атакующему» выгрузить вредоносные файлы на веб сервер. - Межсайтовый скриптинг (XSS): «Атакующий» может внедрить свои скрипты в веб приложение/базу данных. DVWA включает отражённую и хранимую XSS. - Пасхальные яйца: раскрытие полных путей, обход аутентификации и некоторые другие.

DVWA имеет четыре уровня безопасности, они меняют уровень безопасности каждого веб приложения в DVWA: - Невозможный — этот уровень должен быть безопасным от всех уязвимостей. Он используется для сравнения уязвимого исходного кода с безопасным исходным кодом. - Высокий — это расширение среднего уровня сложности, со смесью более сложных или альтернативных плохих практик в попытке обезопасить код. Уязвимости не позволяют такой простор эксплуатации как на других уровнях. - Средний — этот уровень безопасности пред-

назначен главным образом для того, чтобы дать пользователю пример плохих практик безопасности, где разработчик попытался сделать приложение безопасным, но потерпел неудачу. - Низкий — этот уровень безопасности совершенно уязвим и совсем не имеет защиты. Его предназначение быть примером среди уязвимых веб приложений, примером плохих практик программирования и служить платформой обучения базовым техникам эксплуатации. [parasram?]

4 Выполнение лабораторной работы

Настройка DVWA происходит на нашем локальном хосте, поэтому нужно перейти в директорию `/var/www/html`. Затем клонирую нужный репозиторий GitHub (рис. 1).

```
(mobihzova@mobihzova)~$ cd /var/www/html
(mobihzova@mobihzova)-[/var/www/html]
$ sudo git clone https://github.com/digininja/DVWA
[sudo] пароль для mobihzova:
Клонирование в «DVWA»...
remote: Enumerating objects: 5105, done.
remote: Counting objects: 100% (108/108), done.
remote: Compressing objects: 100% (36/36), done.
remote: Total 5105 (delta 79), reused 84 (delta 67), pack-reused 4997 (from 2)
Получение объектов: 100% (5105/5105), 2.45 МиБ | 4.44 МиБ/с, готово.
Определение изменений: 100% (2504/2504), готово.
(mobihzova@mobihzova)-[/var/www/html]
$
```

Рис. 4.1: Клонирование репозитория

Проверяю, что файлы скопировались правильно, далее повышаю права доступа к этой папке до 777 (рис. 2.)

```
(mobihzova@mobihzova)-[/var/www/html]
$ ls
DVWA index.html index.nginx-debian.html
(mobihzova@mobihzova)-[/var/www/html]
$ sudo chmod -R 777 DVWA
```

Рис. 4.2: Изменение прав доступа

Чтобы настроить DVWA, нужно перейти в каталог `/dvwa/config`, затем проверю содержимое каталога (рис. 3)

```
(mobihzova@mobihzova)-[/var/www/html]
$ cd DVWA/config

(mobihzova@mobihzova)-[/var/www/html/DVWA/config]
$ ls
config.inc.php.dist

(mobihzova@mobihzova)-[/var/www/html/DVWA/config]
$
```

Рис. 4.3: Перемещение по директориям

Создаем копию файла, используемого для настройки DVWA `config.inc.php.dist` с именем `config.inc.php`. Копируем файл, а не изменяем его, чтобы у нас был запасной вариант, если что-то пойдет не так (рис. 4)

```
(mobihzova@mobihzova)-[/var/www/html/DVWA/config]
$ sudo cp config.inc.php.dist config.inc.php

(mobihzova@mobihzova)-[/var/www/html/DVWA/config]
$ ls
config.inc.php config.inc.php.dist

(mobihzova@mobihzova)-[/var/www/html/DVWA/config]
$
```

Рис. 4.4: Создание копии файла

Далее открываю файл в текстовом редакторе (рис. 5)

```
(mobihzova@mobihzova)-[/var/www/html/DVWA/config]
$ sudo nano config.inc.php
```

Рис. 4.5: Открытие файла в редакторе

Изменяю данные об имени пользователя и пароле (рис. 6)

```
# See README.md for more information on this.
$_DVWA = array();
$_DVWA['db_server'] = getenv('DB_SERVER') ?: '127.0.0.1';
$_DVWA['db_database'] = getenv('DB_DATABASE') ?: 'dvwa';
$_DVWA['db_user'] = getenv('DB_USER') ?: 'userDVWA';
$_DVWA['db_password'] = getenv('DB_PASSWORD') ?: 'dvwa';
$_DVWA['db_port'] = getenv('DB_PORT') ?: '3306';
```

Рис. 4.6: Редактирование файл

По умолчанию в Kali Linux установлен mysql, поэтому можно его запустить без предварительного скачивания, далее выполняю проверку, запущен ли процесс (рис. 7)

```
(mobihzova@mobihzova)-[~]
$ sudo systemctl start mysql
[sudo] пароль для mobihzova:
[sudo] пароль для mobihzova:

(mobihzova@mobihzova)-[~]
$ systemctl status msq
Unit msq.service could not be found.

(mobihzova@mobihzova)-[~]
$ systemctl status mysql
● mariadb.service - MariaDB 11.4.3 database server
   Loaded: loaded (/usr/lib/systemd/system/mariadb.service; disabled; preset: disabled)
   Active: active (running) since Thu 2025-03-06 12:17:36 MSK; 31s ago
```

Рис. 4.7: Запуск mysql

Авторизируюсь в базе данных от имени пользователя root. Появляется командная строка с приглашением “MariaDB”, далее создаем в ней нового пользователя, используя учетные данные из файла config.inc.php (рис. 8)

```
(mobihzova@mobihzova)-[~]
$ sudo mysql -u root -p
Enter password:
Welcome to the MariaDB monitor.  Commands end with ; or \g.
Your MariaDB connection id is 31
Server version: 11.4.3-MariaDB-1 Debian n/a

Copyright (c) 2000, 2018, Oracle, MariaDB Corporation Ab and others.

Support MariaDB developers by giving a star at https://github.com/MariaDB/server
Type 'help;' or '\h' for help. Type '\c' to clear the current input statement.

MariaDB [(none)]> █
```

Рис. 4.8: Авторизация в базе данных

Теперь нужно пользователю предоставить привилегии для работы с этой базой данных (рис. 9)

```
MariaDB [(none)]> grant all privileges on dvwa.* to 'userDVWA'@'127.0.0.1' identified by 'dvwa';
Query OK, 0 rows affected (0,006 sec)

MariaDB [(none)]> █
```

Рис. 4.9: Изменение прав

Необходимо настроить сервер apache2, перехожу в соответствующую директорию (рис. 10)

```
(mobihzova@mobihzova)-[~]
$ cd /etc/php/8.2/apache2

(mobihzova@mobihzova)-[/etc/php/8.2/apache2]
$
```

Рис. 4.10: Перемещение между директориями

В файле `php.ini` нужно будет изменить один параметр, поэтому открываю файл в текстовом редакторе (рис. 11)

```
(mobihzova@mobihzova)-[/etc/php/8.2/apache2]
$ sudo nano php.ini
```

Рис. 4.11: Открытие файла в текстовом редакторе

В файле параметры `allow_url_fopen` и `allow_url_include` должны быть поставлены как `On` (рис. 12)

```
.....
; Whether to allow the treatment of URLs (like http:// or ftp://) as files.
; https://php.net/allow-url-fopen
allow_url_fopen = On

; Whether to allow include/require to open URLs (like https:// or ftp://) as files.
; https://php.net/allow-url-include
allow_url_include = On
```

Рис. 4.12: Редактирование файла

Запускаем службу веб-сервера `apache` и проверяем, запущена ли служба (рис. 13)

```
(mobihzova@mobihzova)-[/etc/php/8.2/apache2]
$ sudo systemctl start apache2

(mobihzova@mobihzova)-[/etc/php/8.2/apache2]
$ systemctl status start apache2
Unit start.service could not be found.
● apache2.service - The Apache HTTP Server
   Loaded: loaded (/usr/lib/systemd/system/apache2.service; disabled; preset: disabled)
   Active: active (running) since Thu 2025-03-06 12:26:17 MSK; 17s ago
     Invocation: 9c693f0092504e2696021ce710d2cf0c
```

Рис. 4.13: Запуск `apche`

Мы настроили DVWA, Apache и базу данных, поэтому открываем браузер и запускаем веб-приложение, введя `127.0.0/DVWA` (рис. 14)

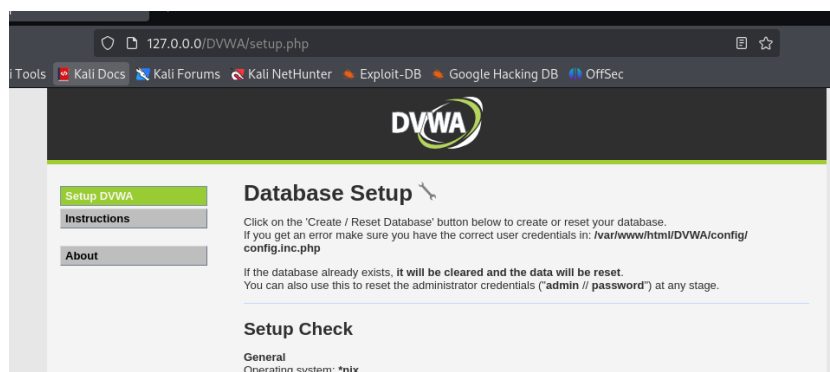


Рис. 4.14: Запуск веб-приложения

Прокручиваем страницу вниз и нажмем на кнопку create\reset database (рис. 15)

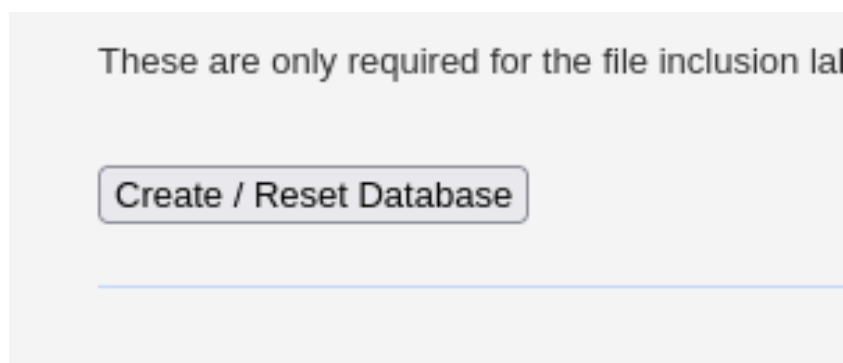


Рис. 4.15: “Создание базы данных”

Авторизуюсь с помощью предложенных по умолчанию данных (рис. 16)

Username

Password

Login

Рис. 4.16: Авторизация

Оказываюсь на домашней странице веб-приложения, на этом установка окончена (рис. 17)

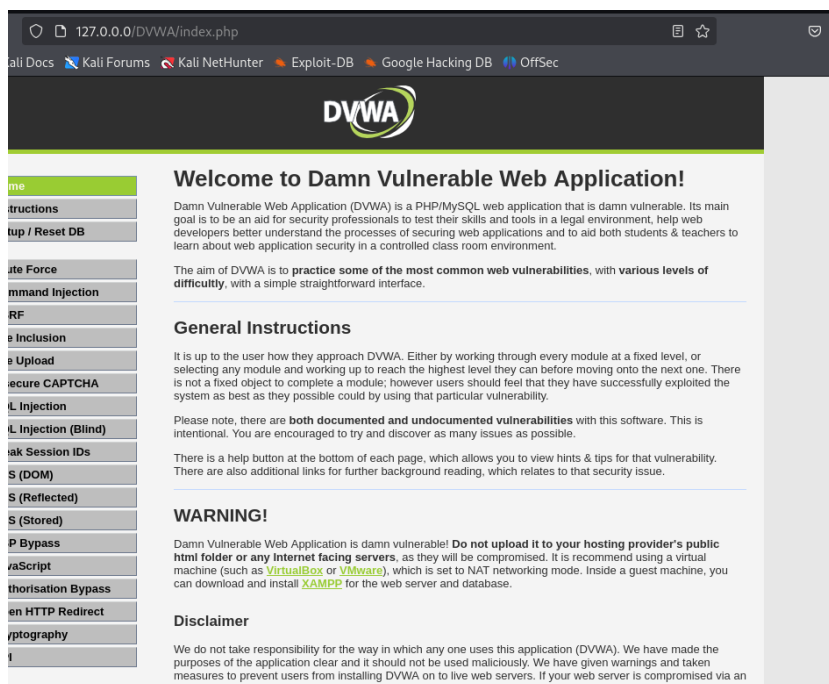


Рис. 4.17: Домашняя страница DVWA

5 Выводы

Приобрела практические навыки по установке уязвимого веб-приложения DVWA.

Список литературы